Практическое задание: Онлайн-магазин электроники «ТехноМаркет»

Краткое описание системы: Интернет-магазин по продаже электроники. Работает круглосуточно, обслуживает ~10 000 пользователей в день, принимает онлайн-платежи, хранит персональные данные клиентов и историю заказов.

Шаг 1. Объекты уязвимости

№	Объект	Категория
1	Сервер БД с заказами	Аппаратный
2	Веб-приложение (корзина, оплата)	Программный
3	База персональных данных клиентов	Информационный
4	Администратор магазина	Человеческий/организационный
5	Конфигурация веб-сервера	Программный

Шаг 2–4. Таблица анализа

Обт уязвимости	Катег ъек ория	Дестабилизирующий фактор	Классификация фактора	Угроза надёжности	Вид угрозы
Сервер БД	Аппаратный	Износ SSD	Внутренний, случайный, постоянный	Отказ диска, потеря заказов	Отказ
Сервер БД	Аппаратный	Скачок напряжения	Внешний, случайный, разовый	Повреждение файлов БД	Потеря целостности

Веб-приложение	Программный	Ошибка в коде оплаты	Внутренний, случайный, постоянный	Зависание корзины	Сбой
Веб-приложение	Программный	SQL-инъекция	Внешний, преднамеренный, периодический	Компрометация сервера	Утечка данных
База клиентов	Информационный	Ошибка прав доступа	Внутренний, случайный, постоянный	Доступ к персональным данным	Утечка данных
База клиентов	Информационный	Инсайдер	Внешний (субъективный), преднамеренный, разовый	Копирование базы	Утечка данных
Администратор	Человеческий	Ошибка настройки firewall	Внутренний, случайный, разовый	Открытие порта БД в сеть	Утечка данных
Администратор	Человеческий	Фишинг	Внешний, преднамеренный, периодический	Кража учётной записи	Утечка данных / отказ
Конфигурация сервера	Программный	Неверное обновление	Внутренний, случайный, периодический	Сбой после обновления	Отказ

Конфигурация сервера	Программный	Слабые пароли	Внутренний, случайный, постоянный	Подбор паролей	Утечка данных

Шаг 5. Меры защиты

Угроза	Мера	Тип
Отказ диска	RAID + резервное копирование	Техническая
Скачок напряжения	ИБП	Техническая
Зависание корзины	Тестирование, обработка исключений	Техническая
SQL-инъекция	Параметризованные запросы, WAF	Техническая
Доступ к персональным данным	Минимальные привилегии, шифрование	Техническая + организационная
Инсайдер	DLP, разграничение доступа	Организационная
Ошибка firewall	Регламент изменений, двойная проверка	Организационная
Фишинг	Обучение, MFA	Организационная + техническая
Сбой обновления	Тестовый стенд, откат версий	Техническая
Слабые пароли	Политика паролей, менеджер секретов	Организационная + техническая

Шаг 6. Наиболее опасная угроза

Утечка базы персональных данных клиентов — наиболее опасна, так как:

- **высокая вероятность** — БД постоянно доступна через веб-приложение;
- **тяжёлые последствия** — штрафы, иски, отток клиентов, репутационный ущерб;
- **необратимость** — скопированные данные вернуть невозможно;
- **скрытность** — утечка может долго оставаться незамеченной.